PRAVEEN V 241901082

Exercise 3

Session Hijacking Using Tools

AIM

To perform session hijacking on a target web application using tools such as Wireshark, Ettercap and Burp Suite, in order to capture, analyze and hijack an active user session by stealing session cookies/tokens.

PROCEDURE

Part A: Capturing Session Using Wireshark

1. Open Wireshark on the attacker machine and select the appropriate network interface.
2. Start capturing packets on the network.
3. On the victim machine, log in to the target web application (e.g., testphp.vulnweb.com) using valid credentials.
4. In Wireshark, apply the filter:
   http.cookie
5. Locate the HTTP GET/POST request containing the Cookie: header and note the session ID (PHPSESSID / JSESSIONID).
6. Copy the captured session ID value.

Part B: Hijacking the Session

1. Open the target website in a different browser (or use a browser extension like Cookie-Editor / EditThisCookie).
2. Open the cookie editor and add/replace the session cookie with the captured session ID value.
3. Refresh the page.

4. Observe that the attacker is now logged in as the victim without entering any credentials, proving the session has been hijacked.

Part C: Session Hijacking Using Ettercap (ARP Poisoning + Hijacking)

1. Open a terminal in Kali Linux and launch Ettercap in GUI mode:
   ettercap -G
2. Select the network interface (eth0) and scan for hosts.
3. Add the victim machine IP to Target 1 and the router/gateway IP to Target 2.
4. Enable ARP poisoning:
   Mitm → ARP Poisoning → Sniff remote connections
5. Start sniffing and wait for the victim to log in to the target site.
6. View captured packets/credentials and session cookies in the Ettercap window.

Part D: Session Hijacking Using Burp Suite

1. Open Burp Suite and configure the browser proxy to route traffic through Burp (127.0.0.1:8080).
2. Turn on Intercept in the Proxy tab.
3. Log in to the target application from the victim browser and capture the login request in Burp.
4. Forward the request and open the HTTP History tab to locate the session cookie in the response headers.
5. Copy the session cookie value and use it in a new request (Repeater tab) to access the application as the victim.
6. Observe that the request succeeds without providing login credentials, confirming session hijacking.

PRAVEEN V 241901082

OBSERVATION TABLE

S.No	Tool Used	Technique	Information / Result Observed
1	Wireshark	Packet capture with http.cookie filter	Session cookie (PHPSESSID) captured
2	Cookie-Editor	Cookie replacement	Logged in as victim using stolen session ID
3	Ettercap	ARP poisoning and sniffing	Victim traffic intercepted, session data captured
4	Burp Suite	Proxy interception and Repeater	Session accessed using captured cookie without login

OUTPUT

Wireshark captured cookie:

Cookie: PHPSESSID=3a8f5c9e1b2d4f6a7c8e9b0d1f2a3c4e

Ettercap output:

ARP poisoning victim: 192.168.1.10 gateway: 192.168.1.1

HTTP : 192.168.1.10:52344 -> 44.228.249.3:80

USER: testuser PASS: test123

COOKIE: PHPSESSID=3a8f5c9e1b2d4f6a7c8e9b0d1f2a3c4e

Burp Suite captured response header:

Set-Cookie: PHPSESSID=3a8f5c9e1b2d4f6a7c8e9b0d1f2a3c4e; path=/

Result after hijacking:

Logged in as: testuser

Session active without credential entry

RESULT

Thus, session hijacking was successfully performed on the target web application using Wireshark, Ettercap and Burp Suite. The session cookie of an active user was captured and reused to gain unauthorized access to the application without providing login credentials.